FOTOMAC — Varredura completa do sistema

Brechas, incoerências, repetições e sugestões de design

17/10/2026

Como ler este relatório

Esta varredura cobriu o sistema web inteiro, de ponta a ponta:

- **Backend:** autenticação, permissões, rotas públicas, envio, publicação, exclusão, trabalhador em segundo plano, banco e armazenamento.
- **Frontend:** painel e site do visitante.
- **Dependências, documentação e processo.**

Nada foi alterado no código. O banco foi limpo a pedido do Thiago: ficou só a conta do administrador, sem eventos, imagens nem vetores. O armazenamento ficou vazio, sem arquivo órfão.

Cada achado tem um código, para facilitar a conversa (ex.: "vamos fazer o A1 e o R1"):

Grupo	O que é
A — Alto	Brecha real ou risco de perder trabalho. Resolver antes de qualquer coisa nova.
M — Médio	Problema que aparece em uso normal ou na implantação.
B — Baixo	Detalhe técnico, limpeza ou ajuste fino.
R — Repetição/incoerência	A mesma coisa feita em dois lugares, ou nomes e regras que se contradizem.
D — Design	Sugestões de tela, para o Thiago aceitar ou recusar. Respeitam o projeto do CITEC.

Para não ficar só no negativo, o que está sólido:

- toda regra de acesso é conferida no servidor;
- a auditoria é inalterável;
- a busca nunca sai de um evento;
- o aceite do visitante é versionado;
- o download fica preso à sessão;
- as chaves estrangeiras do banco são coerentes;
- não há arquivo órfão no armazenamento;
- os 186 testes automatizados passam.

A — Alto

A1. O fotógrafo contratado pode trocar a foto depois de aprovada

O que acontece: o administrador aprova a foto X. Antes da publicação, o contratado usa "Substituir arquivo" e envia outra imagem no lugar. A aprovação continua valendo e a foto nova aparece como "Revisada e aprovada por [administrador]", sem que ele a tenha visto.

Por que importa: a aprovação do RF031 existe justamente para barrar conteúdo impróprio, e o registro de quem aprovou passa a mentir.

Onde: `backend/app/images/service.py`, função `replace_file`. Ela confere se a pessoa enviou a foto, mas não mexe na aprovação.

Correção sugerida: trocar o arquivo de uma foto do contratado a faz voltar para "Aguardando aprovação" e apaga o registro de quem aprovou. Junto, um teste automatizado.

A2. Não existe envio real de e-mail, e o link de demonstração depende disso

O que acontece: o sistema só sabe gravar e-mails em arquivos (`backend/outbox/`). O link de ativação mostrado ao administrador, o trecho TEMPORÁRIO de 14/10, fica ligado sempre que o envio é esse modo de arquivo.

Por que importa: no servidor do CESMAC acontece uma de duas coisas:

- **Sem e-mail:** ninguém recebe ativação, recuperação de senha, aviso de remoção ou aviso de expiração.
- **Mantendo o modo de arquivo:** qualquer administrador consegue ver o link de ativação de qualquer conta, que é exatamente o que o RF001 nota 5 proíbe.

Correção sugerida: antes da implantação, criar o adaptador de e-mail real (SMTP do CESMAC) e ligar o link de demonstração a uma chave própria de desenvolvimento, nunca ao tipo de envio. Isso entra na lista de implantação; não é para agora.

A3. A lista de dependências não reproduz o ambiente

O que acontece: 17 pacotes estão instalados no ambiente local mas não aparecem no `requirements.txt`:

- os do motor de régua InsightFace: `insightface`, `onnxruntime`, `onnx`;
- os de análise de imagem e ciência de dados: `scipy`, `scikit-image`;
- um segundo OpenCV (`opencv-python`), além do `opencv-python-headless`.

Por que importa:

- Numa instalação limpa (servidor do CESMAC, ou o computador de outra pessoa da banca), o teste de precisão perde a régua.
- Dois OpenCV no mesmo ambiente podem se atrapalhar.
- O `requirements.txt` também mistura ferramenta de teste (`pytest`, `httpx`) com o que vai para produção.

Correção sugerida: dois arquivos.

- `requirements.txt`: só produção.
- `requirements-dev.txt`: testes e a régua InsightFace, que é de uso só em pesquisa.

Também remover o OpenCV duplicado.

A4. Nenhum commit desde o início

O que acontece: o git tem um único commit ("Initial commit"). Todo o trabalho desde então (mais de 120 arquivos alterados ou novos, migrações 0008 a 0020) existe só na pasta.

Por que importa:

- Uma pasta apagada, um disco com defeito ou uma sobrescrita errada perde semanas de trabalho.
- Também não há histórico para mostrar a evolução do projeto à banca, que é parte da estratégia combinada.

Correção sugerida: fazer agora um commit com o estado atual (o `.gitignore` já protege fotos, `.env`, e-mails e capturas de tela). Depois, um commit por funcionalidade. Só com o seu OK: commit e push são decisão sua.

M — Médio

M1. Evento com menores: a opção continua na tela, com o requisito suspenso

O RF032 está suspenso até o orientador decidir. Por decisão do Thiago, o código ficou como está. Mesmo assim, o formulário de evento continua oferecendo "Este evento tem participantes menores de 18 anos", e há duas falhas conhecidas:

- **Marcado depois de publicado:** um evento marcado assim **depois** de publicado continua no site;
- **Autorização revogada:** revogar a autorização de um evento publicado também não o tira do site.

Sugestão: esconder a opção do formulário enquanto o RF032 estiver suspenso. Assim ninguém cria um evento infantil por engano. Não precisa apagar código.

M2. A prova de vida aceita fotos colhidas antes

O servidor sorteia a ordem dos movimentos, mas é o navegador que informa qual quadro pertence a qual passo. Quem tiver fotos de uma pessoa com o rosto virado para cada lado (redes sociais, por exemplo) consegue montar a sequência e passar.

Isso é limitação de toda prova de vida feita no navegador, não um erro de código. **Sugestão:** registrar como risco residual nos requisitos (seção de riscos), e não apresentar a prova de vida à banca como "antifraude". Ela barra o caso comum (foto impressa, foto na tela), não um atacante preparado.

M3. Falsificação de pedido entre sites do CESMAC (CSRF)

CSRF é quando outro site faz o navegador de quem está logado enviar um pedido sem a pessoa saber. O cookie de sessão usa a proteção padrão do navegador (SameSite=Lax), que bloqueia sites de fora. Mas ela trata todo `*.cesmac.edu.br` como "o mesmo site".

Se a API ficar num endereço do CESMAC, qualquer outra página hospedada em `*.cesmac.edu.br` poderia disparar, por quem estiver logado, ações sem corpo, como "publicar" ou "excluir evento".

Correção sugerida: o servidor conferir o cabeçalho `Origin` em toda rota que altera dados. É pequena e vale fazer antes da implantação.

M4. Regras da exclusão agendada que só a tela aplica

Durante a exclusão agendada, a tela esconde "Editar evento", mas a API ainda aceita:

- editar o evento;
- abrir ou fechar a colaboração;
- registrar a autorização de menores.

É o mesmo padrão da memória "regra de segurança invisível": a regra precisa estar no servidor.

Correção: bloquear essas três ações no servidor enquanto houver exclusão agendada.

M5. Teto de 200 resultados e a futura pessoa institucional

Já registrado na memória. O teto de 200 é só da busca do visitante. A marcação da pessoa institucional (RF021), que percorre o acervo inteiro, não pode reaproveitá-lo. Entra no planejamento da fase 9.

M6. A documentação de apresentação está atrás do sistema

`docs/ESTRUTURA-DO-SISTEMA.md`, o PDF dele e o `README.md` ainda dizem que a pessoa "tira uma selfie (ou envia uma foto)", e citam os requisitos v1.6 e as três fases antigas.

O sistema agora:

- usa só a captura guiada com prova de vida;
- tem perfil Marketing e conta temporária;
- tem exclusão com prazo.

Se esse documento for para a banca como está, ele contradiz o sistema.

Sugestão: atualizar o README e a ESTRUTURA para a v2.0 antes da próxima banca.

M7. O teste de idade continua no sistema, com o recurso descartado

A estimativa automática de idade foi testada e **descartada** (requisitos v2.0). Mesmo assim, o painel ainda tem a aba "Menores (idade)", com rotas, serviço, o trabalhador rodando a fila dela, tabelas no banco e cerca de 960 linhas de código. Isso é processamento de rosto (inclusive de criança) sem finalidade atual.

Sugestão: remover o recurso. A memória e o HISTORICO guardam o resultado do teste para o TCC.

B — Baixo

Código	Achado	Sugestão
B1	Conta temporária vencida ainda consegue "entrar" se o trabalhador ainda não a marcou como "Expirada"; o pedido seguinte já é recusado.	Conferir a validade também no login.
B2	Ao editar evento trocando a capa, se o nome colidir com outro evento, a capa nova fica esquecida no armazenamento.	Apagar a capa nova quando a gravação falha.
B3	No envio, os arquivos são gravados antes do registro no banco; se o banco falhar, sobra arquivo. Dois envios simultâneos podem passar do limite de 1.000 por poucas imagens.	Limpar em caso de falha; aceitar a pequena folga ou travar a contagem.
B4	A mensagem "O evento atingiu o limite de 1.000 imagens" é texto fixo.	Montar a mensagem a partir do limite (combina com tornar o limite um parâmetro, como discutido).
B5	A lista de eventos faz duas consultas extras por evento. Fica lento com muitos eventos.	Buscar tudo de uma vez.
B6	O GPS é removido, mas o número de série da câmera e o nome do dono (quando a câmera grava) continuam no original que o visitante baixa.	Remover também na etapa 4 (download com marca d'água).
B7	Miniaturas do painel ficam 10 minutos no cache do navegador; em computador compartilhado, continuam lá depois de "Sair".	Reduzir ou desligar o cache das imagens do painel.
B8	A documentação automática da API (`/api/v1/docs`) é pública.	Fechar em produção.
B9	O limite de pedidos é por endereço IP; atrás do proxy do servidor, todo mundo parece o mesmo IP.	Configurar o proxy para repassar o IP real (lista de implantação).
B10	`backend/outbox/` tem 179 e-mails de teste com endereços de pessoas.	Apagar (dado pessoal sem finalidade).

R — Repetições e incoerências

Código	Achado	Sugestão
R1	**Duas telas para conferir e publicar:** a antiga "Conferir imagens" (Figma 08) e a aba Imagens (nova). São dois visualizadores, dois botões de publicar e duas grades. Hoje só o fim do envio ainda leva para a antiga.	Ficar só com a aba Imagens. O visualizador da conferência (navegação ← →, descartar, substituir) vira o detalhe da imagem.
R2	**"Fotos" e "imagens" misturados:** "Quantidade de fotos", "Fotos publicadas", "Enviar imagens", "3 fotos aguardam aprovação".	Usar "imagem" em todo o painel (decisão do Thiago: imagem = foto ou vídeo).
R3	Criar tema existe em duas rotas da API (a do formulário de evento e a da tela Temas).	Uma rota só.
R4	Números repetidos na tela e no servidor (500 por envio, 25 MB, domínio institucional, quem pode enviar). Mudar um exige mudar dois.	O servidor informar os limites à tela, como já faz com as regras de senha.
R5	"Em edição" serve para dois casos: evento nunca publicado e evento despublicado após desfazer a exclusão.	Aceitável hoje; se confundir, mostrar "Despublicado" no segundo caso.

D — Sugestões de design (aceitar ou não)

Todas mantêm o padrão visual do CITEC: cores, fontes, cartões e componentes iguais. Mudam só a organização.

Código	Hoje	Sugestão
D1	A visão geral do evento empilha até 5 avisos coloridos (próxima ação, criança por acaso, baixar acervo, prazo de retenção, exclusão). Fica poluída, e o importante se perde.	Um cartão **"Próximos passos"** com a sequência enviar → conferir → publicar → baixar, marcando o que já foi feito. Avisos coloridos só para o que é urgente (exclusão agendada, aprovação pendente).
D2	O painel do **administrador** mostra "Meus eventos 0" e "Fotos publicadas 0"; o administrador não cria eventos, então os números não dizem nada.	Contadores do administrador: eventos ativos, imagens aguardando aprovação, remoções pendentes, falhas de processamento.
D3	A aba Imagens mostra 9 filtros, a maioria com zero ("Falha · 0", "Remoção solicitada · 0"…).	Mostrar só "Todas" e os filtros que têm imagens.
D4	Com exclusão agendada, a etiqueta do topo diz "Em edição".	A etiqueta diz "Exclusão agendada".
D5	O envio termina levando à conferência antiga.	Terminar na aba Imagens, já filtrada em "Em conferência", com a barra de publicar à vista (combina com R1).

Ordem sugerida

1. **A4:** commit do estado atual (com o seu OK).
2. **A1:** fechar a brecha da troca de arquivo depois da aprovação.
3. **A3:** corrigir as dependências.
4. **M4 e M3:** regras no servidor.
5. **R1, R2, D1–D5:** limpeza de telas, se aprovadas.
6. **M7:** remover o teste de idade.
7. **M6:** atualizar README e ESTRUTURA para a v2.0.
8. **Antes da implantação:** A2, B8 e B9 (lista de implantação).
9. **Dependem de decisão externa:** M1 e M2 (orientador, jurídico), M5 (fase 9).